

بنك الأفاق الرقمي — تقرير أداء نظام إدارة أمن المعلومات

التصنيف := داخلي — يجوز مشاركة هذه الوثيقة مع الأطراف المعنية والجهات الرقابية خارج بنك الأفاق الرقمية بموافقة مسبقة من CISO.

الإصدار	معتمد من	مالك الوثيقة	تاريخ آخر تحديث	دورية المراجعة	المراجعة القادمة	الملاحظات
1.0	د. نورة القحطاني (الرئيس التنفيذي) ولجنة المخاطر بمجلس الإدارة	أ. سارة الحربي (مدير أمن المعلومات - CISO)	12 سبتمبر 2026	ربع سنوي	ديسمبر 2026	تقرير الأداء الدوري الشامل لنظام إدارة أمن المعلومات (الربع الثالث 2026) بموجب البند 9.1 من مواصفة ISO/IEC 27001:2022 وإطار SAMA CSF.

دلالات ألوان ومستويات الحالة	أخضر: محقق للهدف أو يتجاوزه تماماً.	كهرماني: ضمن 10% من المستهدف أو توجد خطة معالجة نشطة.	أحمر: أقل بكثير من الهدف أو لا توجد خطة معالجة.
------------------------------	-------------------------------------	---	---

مؤشر القياس	الوصف التفصيلي	دورية القياس	المستهدف / العتبة	مصدر البيانات	الحالة	النتائج المحققة الفعلية	التعليقات وخطط المعالجة	آخر مراجعة
الامتثال لمراجعة السياسات	نسبة الموظفين الذين قرؤوا وأقروا بالالتزام بالسياسات الرئيسية لأمن المعلومات.	ربع سنوي	100% إقرار وتعهد	نظام الموارد البشرية HR Portal	كهرماني	إقرار 2,452 موظفاً من أصل 2,500 موظف بنسبة 98.1% والمتبقي 48 موظفاً بإجازات مرضية وابتعاث	المتبقي 28 موظفاً (إجازات أمومة، مرضية، وابتعاث)؛ تم تأجيل توقيعهم حتى عودتهم للعمل مع تفعيل تنبيه آلي عند تسجيل الدخول.	سبتمبر 2026
أ. سياسة أمن المعلومات	مراجعة وإقرار جميع منسوبي البنك بسياسة أمن المعلومات المعتمدة (ISMS-DOC-05-4).	ربع سنوي	100%	بوابة الموارد البشرية	كهرماني	إقرار 2,452 موظفاً من أصل 2,500 موظف بنسبة 98.1% والمتبقي 48 موظفاً بإجازات مرضية وابتعاث	مطابق لمعايير الامتثال؛ تم توجيه تذكير أسبوعي للموظفين المنضمين حديثاً لإكمال الإقرار خلال 7 أيام.	سبتمبر 2026
ب. سياسة الاستخدام المقبول	امتثال كافة الموظفين بالإقرار بسياسة الاستخدام المقبول	ربع سنوي	100%	بوابة HR ونظام الدومين	كهرماني	إقرار 2,452 موظفاً من أصل 2,500 موظف	تم ربط الدخول على شبكة البنك بإقرار السياسة إلكترونياً عند	سبتمبر 2026

							للأصول والأجهزة (AUP).
	بنسبة 98.1% والمتبقي 48 موظفاً بإجازات مرضية وابتعاث						
سبتمبر 2026	اكتمال التوقيع والالتزام الكامل بضوابط منع رفع البيانات غير المشفرة على مستودعات AWS S3.	100% (إقرار 85 موظفاً ومهندساً من الفريق المعني).	أخضر	نظام إدارة الكفاءات IT	100%	ربع سنوي	ج. سياسة الخدمات السحابية امتثال فرق تقنية المعلومات والسحابة والعمليات بإقرار سياسة أمن السحابة.
سبتمبر 2026	تم دمج معايير OWASP Top- 10 وفحص الكود الآلي (SAST/DAST) ضمن مسار التطوير المستمر CI/CD.	100% (إقرار كافة المطورين البالغ عددهم 42 مطوراً).	أخضر (Green)	بوابة Git وقسم البرمجة	100%	ربع سنوي	د. سياسة التطوير الآمن امتثال فرق هندسة وتطوير البرمجيات والتطبيقات بالسياسة البرمجية الآمنة.
سبتمبر 2026	5 ضوابط قيد الاكتمال والتفعيل النهائي: تشفير BitLocker الشامل، مزامنة توقيت NTP المركزية، استبدال تطبيق سبيروولا، خوادم النسخ WORM، ونظام PAM.	94.6% (تطبيق وتشغيل 88 ضابطاً من أصل 93 ضابطاً منطبقاً).	كهرماني	سجلات التدقيق الداخلي ومصفوفة SoA	100% من الضوابط المشمولة في النطاق	سنوي / ربع سنوي	نسبة ضوابط معيار ISO/IEC 27001:2022 المطبقة والجاهزة للتشغيل وفق بيان الانطباق (SoA).
أغسطس 2026	شملت المراجعة: مزود السحابة AWS، شركة الاتصالات stc، مورد الحماية Trend Micro، وشركات الدفع الإلكتروني.	100% (مراجعة كافة الموردين الحرجين البالغ عددهم 18 مورداً).	أخضر	جدول مراجعة عقود الموردين	100%	سنوي	مراجعات الموردين والشركاء نسبة الموردين ومزودي الخدمات السحابية والتقنية الذين تمت مراجعتهم وفق الجدول.
أغسطس 2026	تم التحقق من حصول 15 مورداً على شهادة ISO 27001 سارية، وتوقيع اتفاقيات حماية البيانات ومعايير SLA المصرفية.	100% (إنجاز تقييمات المخاطر لـ 18 مورداً رئيسياً).	أخضر	سجل تقييم مخاطر سلاسل التوريد	100%	سنوي	تقييم مخاطر الموردين يتملكون تقييمات مخاطر أمنية محدثة. نسبة الموردين الحرجين الذين

التدريب والتوعية الأمنية =	مؤشرات إنجاز البرامج التدريبية والتوعوية التخصصية لمنسوبي البنك والمقاولين.	ربع سنوي	100%	منصة التعلم الإلكتروني وسجلات التدريب	كهرماني	95.3% الإنجاز العام لبرامج التوعية.	حملة توعية مكثفة مستمرة لرفع نسبة إبلاغ الموظفين عن رسائل التصيد الاحتيالي من 8% إلى المستهدف 75%.	سبتمبر 2026
أ. مقدمة في معيار ISO 27001	نسبة الموظفين الذين أتموا الدورة التعريفية بنظام إدارة أمن المعلومات (ISMS).	ربع سنوي	100%	سجلات منصة التدريب LMS	كهرماني	94.2% (إتمام 1,413 موظفاً للدورة التدريبية).	تم إطلاق مسار تدريب إلكتروني مكثف لمدة 30 دقيقة للموظفين المتبقين لإكمال المتطلب قبل التدقيق الخارجي.	سبتمبر 2026
ب. التدريب على حماية البيانات	نسبة الموظفين الذين اجتازوا تدريب نظام حماية البيانات الشخصية والأمن السيبراني.	ربع سنوي	100%	منصة الامتثال والتدريب	كهرماني	92.5% (اجتياز 1,388 موظفاً).	تم التركيز على موظفي الفروع وخدمة العملاء والعمليات لضمان الامتثال لمتطلبات هيئة SDAIA والبنك المركزي.	سبتمبر 2026
ج. اتفاقيات السرية للمقاولين	نسبة المقاولين والمستشارين الخارجيين الموقعين على اتفاقيات عدم الإفصاح والسرية.	سنوي / مستمر	100%	سجلات إدارة العقود والشؤون القانونية	أخضر)	100% (توقيع 64 مقاولاً واستشارياً خارجياً).	لا يتم إصدار أي تصريح دخول لمراكز البيانات أو حسابات الشبكة إلا بعد استلام اتفاقية NDA الموقعة وموافقة CISO.	سبتمبر 2026
مراجعة بيان الانطباق	نسبة الضوابط التي تمت مراجعتها وتحديثها سنوياً في وثيقة بيان الانطباق (SoA).	سنوي	100%	سجلات مراجعة الوثائق المعتمدة	أخضر	100% (تمت مراجعة واعتماد كافة الضوابط الـ 93).	تم اعتماد بيان الانطباق الإصدار 1.0 بتاريخ أغسطس 2026 بمواصفة كاملة مع ضوابط ISO 27001:2022 وإطار SAMA CSF.	أغسطس 2026
حوادث أمن المعلومات	عدد حوادث أمن المعلومات المسجلة وحالة معالجتها وإغلاقها.	شهري / ربع سنوي	صفر حوادث معلقة دون حل	نظام إدارة الحوادث بمركز SOC	أخضر	4 حوادث مسجلة خلال الربع؛ تم حلها وإغلاقها بالكامل (100% Resolved).	الحوادث: فقدان لابتوب مشفر بالخارج (مسح عن بُعد)، محاولة تصيد بريدي (حجب)، انحراف توقيت NTP (ضبط وتوحيد)، ومحاولة دخول غير مصرح	سبتمبر 2026

بسيرفر تجريبي.								
زمن الاستجابة للحوادث وحلها	متوسط الوقت المستغرق للاستجابة للحوادث الأمنية ومعالجتها وفق اتفاقيات SLA.	شهري / ربع سنوي	ضمن حدود SLA المعتمدة (الدرجة > ساعتين، العالية > 4 ساعات)	أداة تتبع تذاكر SOC IT Service Desk	أخضر	الحوادث الحرجة: 1.2 ساعة (المستهدف > 2 ساعة). الحوادث العالية: 2.8 ساعة (المستهدف > 4 ساعات).	التزام تام بأوقات الاستجابة؛ وتم تفعيل بروتوكول إشعار البنك المركزي السعودي SAMA خلال المدد النظامية.	سبتمبر 2026
تدقيق صلاحيات الوصول	نسبة حسابات وصلاحيات الوصول المنطقي والمادي التي تمت مراجعتها دورياً.	سنوي / ربع سنوي	100% من حسابات الوصول المحددة	سجلات تدقيق الدليل النشط Active Directory	أخضر	98.4% من إجمالي الحسابات والصلاحيات.	تمت مراجعة وإلغاء 115 حساباً غير نشط أو زائد عن الحاجة، وسحب صلاحيات الدومين الإدارية الموروثة عن مجلدات الرواتب.	أغسطس 2026
نتائج التدقيق الداخلي لنظام ISMS	عدد وشدة الملاحظات وحالات عدم المطابقة المسجلة في التدقيق الداخلي لنظام ISMS.	سنوي	عدم وجود حالات كبرى حرجة، وخفض الملاحظات الصغرى	سجلات وتقرير التدقيق الداخلي IA-2026-01	كهرماني	حالة عدم مطابقة كبرى (NCR142)، حالة عدم مطابقة صغرى (NCR143)، وملاحظة تحسينية (OBS163).	حالة NCR142 تتعلق بأهداف أمن المعلومات ومؤشراتها، وNCR143 بمعايير استثناء الأنظمة التراثية؛ تم اعتماد خطة معالجة فورية وتعيين مالكي التنفيذ.	سبتمبر 2026
فاعلية مراجعة الإدارة العليا	أدلة عقد اجتماعات مراجعة الإدارة ومتابعة قرارات وتوصيات التحسين المستمر.	سنوي / نصف سنوي	100% اجتماع سنوي موثق	محاضر وقرارات مراجعة الإدارة العليا	أخضر	100% (عقد الاجتماع السنوي لمراجعة الإدارة في 10 سبتمبر 2026).	تمت مناقشة أداء النظام، تقارير الحوادث، تخصيص ميزانية الـ 18 مليون ريال، واعتماد خطط المعالجة من الرئيس التنفيذي ولجنة المخاطر.	سبتمبر 2026
إدارة المخاطر السيبرانية	مؤشرات حصر وتقييم ومعالجة وقبول مخاطر أمن المعلومات بالبنك.	ربع سنوي	معالجة 100% من المخاطر الحرجة والعالية	سجل المخاطر (Risk Register v1.0)	أخضر	تم تقييم 25 خطراً رئيسياً موزعة على البنية التحتية والعمليات المصرفية.	تم توثيق كافة المخاطر في تقرير تقييم المخاطر (ISMS-DOC-06-3) وربطها بضوابط الملحق A لمواصفة ISO 27001.	سبتمبر 2026

أ. المخاطر المحددة	إجمالي عدد مخاطر أمن المعلومات المسجلة خلال فترة إعداد التقرير.	ربع سنوي	مؤشر إحصائي (N/A)	سجل المخاطر المعتمد	أخضر	25 خطراً مصرفياً وتقنياً محدداً ومصنفاً.	تتوزع إلى: 4 مخاطر حرجية، 9 مخاطر عالية، 8 مخاطر متوسطة، و4 مخاطر منخفضة.	سبتمبر 2026
ب. المخاطر المعالجة والخاضعة للتخفيف	نسبة المخاطر المحددة التي خضعت لخطط معالجة وضوابط تخفيف ضمن المدى الزمني.	ربع سنوي	100% من المخاطر الحرجية والعالية	سجل وخطط معالجة المخاطر	أخضر	100% (21 خطراً من أصل 21 خطراً تستوجب المعالجة تخضع لخطط تخفيف نشطة).	تم إطلاق مشاريع التشفير الشامل TDE/BitLocker، وتعزيز أمن البريد Defender، وعزل الشبكات وربط توقيت NTP بالبنك المركزي.	سبتمبر 2026
ج. المخاطر المقبولة رسمياً	نسبة المخاطر المقبولة رسمياً بموجب موافقات خطية مسبقة من الإدارة العليا.	ربع سنوي	مؤشر إحصائي يخضع لشهية المخاطر (Score <= 4) أو استثناء مؤقت	سجل المخاطر ونماذج الاستثناءات الأمنية	أخضر	4 مخاطر مقبولة رسمياً (16% من إجمالي المخاطر المسجلة).	تشمل: 3 مخاطر منخفضة بطبيعتها، وقبول مؤقت مشروط لمدة 60 يوماً لمخاطر تطبيق سيبيرولا التراثي لحين استبداله في الربع الثالث 2026.	سبتمبر 2026
إدارة التغييرات الأمنية	مؤشرات الامتثال لضوابط إدارة التغيير والتحكم في التعديلات التقنية.	شهري / ربع سنوي	100% امتثال وتفادي التغييرات العشوائية	سجلات أداة إدارة التغيير ITSM ونظام CAB	أخضر	التزام بنسبة 99.4% بمسار التغيير المعتمد.	يتم تقييم كافة التغييرات تقنياً وأمنياً من قبل لجنة اعتماد التغييرات (CAB) قبل تطبيقها على بيئة الإنتاج المصرفية.	سبتمبر 2026
أ. الامتثال لاعتماد التغييرات	نسبة التغييرات المنفذة التي اتبعت مسار الموافقة المسبقة من لجنة CAB.	شهري / ربع سنوي	100%	سجلات نظام إدارة التغييرات	أخضر	99.4% (تنفيذ 328 تغييراً معتمداً من أصل 330 طلباً؛ 2 ألغيا لعدم استيفاء الفحص الأمني).	التغييرات الطارئة (Emergency Changes) خضعت لاعتماد فوري من CISO وCTO وتم توثيقها بأثر رجعي خلال 24 ساعة.	سبتمبر 2026
ب. التغييرات غير المصرح بها	عدد التعديلات أو التغييرات غير المصرح بها التي تم رصدها على الأنظمة الحية.	شهري / ربع سنوي	صفر تغييرات غير مصرح بها (Zero)	أداة مراقبة تكامل الملفات (FIM) وسجلات الخوادم	أخضر	صفر (0) تغييرات غير مصرح بها.	أنظمة مراقبة التغييرات (Tripwire/FIM) لم تسجل أي تعديل غير نظامي على ملفات التكوين أو قواعد البيانات	سبتمبر 2026

								المصرفية.
اختبارات استمرارية الأعمال والتعافي	عدد ونتائج اختبارات محاكاة خطط استمرارية الأعمال والتعافي من الكوارث.	سنوي	إجراء اختبار محاكاة سنوي ناجح على الأقل	سجلات وتقارير اختبارات DR المعتمدة	أخضر	تم تنفيذ اختبار محاكاة سنوي متكامل بنجاح في يوليو 2026.	تمت محاكاة انقطاع مركز بيانات الرياض والتحول التلقائي لمركز بيانات جدة؛ تحقق زمن التعافي RTO خلال 42 دقيقة (الهدف > ساعتين) وفقدان بيانات RPO صفر.	يوليو 2026
دقة حصر الأصول وتصنيفها	نسبة الأصول التقنية المصنفة والمحددة بالمالك ضمن نطاق نظام إدارة أمن المعلومات.	ربع سنوي	100% من أصول النطاق	نظام إدارة الأصول CMDDB ونظام Intune	أخضر	100% حصر وتصنيف 2,000 لابتوب للموظفين و 250 خادماً فيزيائياً وافترضياً وقاعدة بيانات.	تم تصنيف الأصول وفق معايير الحساسية وسجل الأصول المحدث، مع تعيين مسؤول ومالك لكل أصل وربط الأجهزة بنظام Intune.	سبتمبر 2026
معالجة الثغرات الأمنية	نسبة الثغرات الأمنية المكتشفة التي تم حلها وترقيعها ضمن اتفاقية مستوى الخدمة SLA.	شهري / ربع سنوي	100% من الثغرات الحرجة خلال 14 يوماً	تقارير المسح الدوري بأداة Tenable/Nessus	كهرماني	الثغرات الحرجة: 100% خلال 14 يوماً. الثغرات العالية: 93.8% خلال 30 يوماً.	تم ترقيع كافة الثغرات الحرجة؛ وتوجد خطة معالجة جارية لترقيع المتبقي من الثغرات العالية غير المؤثرة على العمليات الحيوية قبل نهاية الشهر.	سبتمبر 2026
الامتثال لمراجعة وتحديث الوثائق	نسبة وثائق وسياسات وإجراءات ISMS التي تمت مراجعتها وتحديثها دورياً.	سنوي	100% مراجعة وتحديث	سجل مراقبة وثائق نظام إدارة أمن المعلومات	أخضر	100% (مراجعة وتحديث كافة الوثائق الـ 24 المعتمدة لعام 2026).	شمل التحديث: السياسة العامة، الاستخدام المقبول AUP، إجراءات تشغيل IT M8، خطة الحوادث A05-26-1، وبيان الانطباق SoA.	سبتمبر 2026
الامتثال لإلغاء صلاحيات المنتهية خدماتهم	نسبة الموظفين المنتهية خدماتهم الذين تم إلغاء كافة صلاحيات وصولهم ضمن اتفاقية SLA.	شهري / ربع سنوي	100% خلال أقل من 24 ساعة من تاريخ الإنهاء	سجلات تذاكر الموارد البشرية والدليل النشط AD	أخضر	100% (إلغاء صلاحيات 14 موظفاً منتهية خدماتهم بمتوسط 3.5 ساعات).	يتم استلام إشعار إنهاء الخدمة آلياً من نظام HR وتجريد الحسابات وسحب بطاقات الدخول البيومترية واستلام الأجهزة المحمولة فوراً.	سبتمبر 2026

